

Botium Toys - Controls and Compliance

Checklist Security Audit

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege Explanation: All Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers’ PII/SPII.
☐	☒	Disaster recovery plans Explanation: There are no disaster recovery plans currently in place, and the company does not have backups of critical data.
☐	☒	Password policies Explanation: Password requirements are nominal and not in line with current minimum password complexity requirements (e.g., at least eight characters, a combination of letters and at least one number; special characters).

- ☐ ☒ Separation of duties

Explanation: Access controls pertaining to least privilege and separation of duties have not been implemented.

- ☒ ☐ Firewall

Explanation: The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.

- ☐ ☒ Intrusion detection system (IDS)

Explanation: The IT department has not installed an intrusion detection system (IDS).

- ☐ ☒ Backups

Explanation: the company does not have backups of critical data.

- ☒ ☐ Antivirus software

Explanation: Antivirus software is installed and monitored regularly by the IT department.

- ☐ ☒ Manual monitoring, maintenance, and intervention for legacy systems

Explanation: While legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear.

☐ ☒ Encryption

Explanation: Encryption is not currently used to ensure confidentiality of customers' credit card information.

☐ ☒ Password management system

Explanation: There is no centralized password management system that enforces the password policy's minimum requirements.

☒ ☐ Locks (offices, storefront, warehouse)

Explanation: The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks, up-to-date

☒ ☐ Closed-circuit television (CCTV) surveillance

Explanation: up-to-date closed-circuit television (CCTV) surveillance.

☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

Explanation: functioning fire detection and prevention systems.

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select "yes" or "no" to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information. Explanation: All Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. Explanation: Credit card information is not encrypted and all employees currently have access to internal data, including customers' credit card information.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data. Explanation: At present, the organization does not employ encryption to safeguard the confidentiality of customer financial records.
☐	☒	Adopt secure password management policies. Explanation: Password requirements are nominal and not in line with current minimum password complexity requirements

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured. Explanation: The company does not currently use encryption to better ensure the confidentiality of customers' financial information.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. Explanation: The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach.
☐	☒	Ensure data is properly classified and inventoried. Explanation: Current assets have been inventoried/listed, but not classified.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data. Explanation: Privacy policies, procedures, and processes have been developed and enforced among IT team members and other employees, as needed.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
		Explanation: Access controls pertaining to least privilege and separation of duties have not been implemented.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
		Explanation: Encryption is not practiced.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
		Explanation: Data integrity is in place.
☐	☒	Data is available to individuals authorized to access it.
		Explanation: Authorization needs to be limited to only the individuals who need access to it to do their jobs.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

To strengthen Botium Toys' security posture and better safeguard the confidentiality of sensitive data, several key controls must be established. These security measures include the principle of Least Privilege, comprehensive disaster recovery plans, robust password policies, strict separation of duties, an Intrusion Detection System (IDS), ongoing management of legacy systems, data encryption, and a dedicated password management system. Furthermore, addressing existing compliance gaps requires the immediate implementation of specific controls such as Least Privilege, encryption, and separation of duties. Accurately classifying organizational assets will also be essential to identifying further security controls necessary to protect sensitive information and improve the company's overall defense mechanisms.